

THE EDUCATOR · CPCS 351

Topic 13

Security & Privacy

A complete, study-ready edition of the live Topic 13 content - with the original lecture case, course visuals, scenario practice, and one consistent design system.

Privacy & CIA Threats & Attacks User Security
Password Policy Software Security Secure Design Malware

7 lessons · full lesson content · real-world case · visual anchors · self-feedback

Golden Master · v1.0

Topic 13

Contents

Seven lessons forming one security story: understand privacy and information security, distinguish threats and access controls, strengthen user and software security, apply secure-design principles, and recognize malware.

Lesson 1

Security & Privacy Foundations

Lesson 2

Privacy & Information Security

Lesson 3

Security Terms & User Security

Lesson 4

Recommended Password Policy

Lesson 5

Software Security

Lesson 6

Secure Software Design

Lesson 7

Malware & Topic Review

Golden Master rule

This PDF preserves the instructional content of the live Topic 13 pages and the supplied lecture slides. The real-world confidentiality case is reproduced from the supplied lecture visual; the large Topic 13 and Mission 13 infographics are the visual anchors used by the course.

TOPIC 13 · LESSON 01

Security & Privacy Foundations

Start with the threat landscape, understand the consequences of attacks, and frame Topic 13 as a connected engineering problem.

Start with the puzzle

A hospital can have strong clinical procedures and still fail patients if its digital systems expose records, alter data, or become unavailable. What exactly are we trying to protect?

Learning Focus

Identify the major sources of threats and classify the consequences of security incidents as information, operational, personal, or organizational risks.

Running Story · Jeddah Smart Hospital

A patient checks in through a hospital app. Minutes later, an employee opens a record they do not need, a malicious file reaches a workstation, and the appointment service becomes unavailable. Follow this story through Topic 13: each lesson asks what information matters, what can go wrong, and what protection is appropriate.

Sources of Threats

- Hackers - deliberate human attempts to steal, damage, or misuse information.
- Viruses and malware - malicious software that can damage systems or gain unauthorized access.
- Poorly designed systems - weaknesses created by insecure design or implementation.
- Insiders (employees) - people with legitimate organizational access who may misuse it intentionally or unintentionally.
- People's ignorance and lack of knowledge - human mistakes and weak security awareness.
- Disasters and other incidents affecting information systems - events that can disrupt systems and services.

Consequences of Security Attacks

- Information risks: unauthorized access/disclosure of confidential information; unauthorized addition, deletion, or modification of information.
- Operational risks: the system is not functional (Denial of Service, DoS) or is operated incorrectly.
- Personal risks: identity theft, financial loss, disclosure that affects employment or other personal aspects such as health information, and physical/psychological harm.
- Organizational risks: financial losses and organizational damage, including reputational harm.



Visual Anchor · Topic 13 master learning map

Remember

Security incidents can affect information, operations, individuals, and organizations at the same time. Security engineering therefore needs layered controls, not a single “security feature.”

TOPIC 13 · LESSON 02

Privacy & Information Security

Separate the question “Should we collect/use this information?” from “How do we protect the information and system?”

Start with the puzzle

A hospital app asks for full identity data, home address, location, contacts, and photos just to book a routine appointment. Which part is a privacy problem, and which part is an information-security problem?

Learning Focus

Explain privacy, information security, the three privacy practices in the lecture, and the Confidentiality-Integrity-Availability (CIA) triad.

Core Definitions

Privacy

The ability of an individual or group to seclude themselves or information about themselves and reveal themselves selectively.

Information Security

Protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, inspection, recording, or destruction.

Three Privacy Practices

Data Minimization

Limit collection and retention of personal information to only what is necessary for a specific purpose. Example: an online shop collects only the name, address, and payment information required for checkout.

Anonymization

Remove or encrypt personally identifiable information so individuals cannot be identified. Example: health researchers anonymize patient data before analyzing trends.

User Consent

Individuals should control how personal information is collected, used, and shared. Example: a mobile app requests location access and the user explicitly grants or denies permission.

Information Security: the CIA Triad

Confidentiality

Protect sensitive information from unauthorized access or disclosure.

Integrity

Assure that data remains accurate, consistent, and unaltered.

Availability

Keep data and resources accessible and usable when needed.

Real-World Case · Confidentiality

The supplied lecture uses a news report about hospital staff accessing actor George Clooney's confidential medical information after a motorcycle accident. The engineering lesson is broader than celebrity privacy: being technically able to open a record does not mean a user is authorized to view it.

Hospital staffers suspended over Clooney

Posted 10/10/2007 10:45 AM | Comment | Recommend

E-mail | Print |



Enlarge

By Carolyn Kaster, AP

Several hospital staffers have been suspended for allegedly peeking at George Clooney's confidential medical information after he was hurt in a motorcycle accident last month.

NORTH BERGEN, N.J. (AP) — Several hospital staffers have been suspended for allegedly peeking at George Clooney's confidential medical information after he was hurt in a motorcycle accident last month.

Clooney, 46, suffered a broken rib and scrapes in the Sept. 21 crash, while his passenger, Sarah Larson, 28, broke her foot. Both were treated at Palisades Medical Center in North Bergen.

WCBS-TV in New York reported Tuesday night that as many as 40 staffers, including doctors, were suspended without pay, accused of accessing Clooney's medical records and possibly providing information to the media, a violation of federal law.



Other ways to share:



What's this?

Source visual from the supplied lecture slides: hospital staffers were reported suspended over unauthorized access to confidential medical information.

Engineering interpretation

The central CIA property is Confidentiality. Later Topic 13 concepts strengthen the response: Authorization should restrict access according to policy, and Least Privilege should give each user only the access required for their role.

Try it

A nurse cannot open a patient record during treatment. Which CIA property is directly affected?
Self-feedback: Availability - authorized users cannot access the resource when needed.

TOPIC 13 · LESSON 03

Security Terms & User Security

Use precise vocabulary for harmful scenarios, exploitable weaknesses, breach attempts, and access-control decisions.

Start with the puzzle

An attacker wants patient data. The system has a weak input-validation routine. Which part is the threat, which is the vulnerability, and which is the attack?

Learning Focus

Distinguish Attack, Threat, and Vulnerability; then distinguish Identification, Authentication, and Authorization and connect Authorization to Least Privilege.

Threat

A scenario that can harm a system.

Vulnerability

The “hole” or weakness that can be used in an attack.

Attack

An attempt to breach system security.

Threat → Vulnerability → Attack

Example: the possibility that someone may target hospital records is a threat. Weak input validation is a vulnerability. The actual attempt to exploit that weakness and reach the records is an attack.

User Security

Identification

Identifying who you are, usually using a user ID or another unique code.

Authentication

Confirming that you truly are who you identify as, commonly using keys, PINs, passwords, or biometrics.

Authorization

Specifying or verifying how much access an authenticated user has, based on owner policy and system configuration. The lecture highlights the Principle of Least Privilege.

Try it

Should a receptionist automatically have the same access as a system administrator?

Self-feedback: No. Authorization should reflect the required role, and Least Privilege limits access to what the job actually needs.

TOPIC 13 · LESSON 04

Recommended Password Policy

Apply the lecture's password recommendations without confusing memorability with security.

Start with the puzzle

A password such as 11111111 is eight characters long. Does meeting the length recommendation make it a good password?

Learning Focus

Explain the lecture recommendations for password length, complexity, unpredictability, and resistance to brute-force, dictionary, and guessing attacks.

Recommended Password Policy

- Length: 8 characters or more, presented in the lecture as a way to slow brute-force attacks.
- Complexity: use characters from 3 of 4 categories - uppercase letters, lowercase letters, numbers, and symbols.
- Avoid symbols that have special system uses or can create security problems in the system context.
- No meaning: avoid common dictionary words to reduce dictionary-attack effectiveness.
- Avoid simple patterns such as 12345678 or 11111111.
- Avoid easily guessed information such as birthdays and family names.

Why “Jeddah1984” can still be weak

It feels memorable precisely because it contains meaningful and potentially guessable information. The lecture warns against dictionary words, simple patterns, and personal information that known or unknown attackers may guess.

Try it

Password: 11111111. What is wrong according to the lecture?

Self-feedback: It is a simple predictable pattern and lacks the recommended category complexity.

Remember

A password policy is not only about length. The lecture combines length, character-category complexity, and resistance to meaningful, patterned, or personally guessable passwords.

TOPIC 13 · LESSON 05

Software Security

Many security bugs begin as programming assumptions that hold during normal use but fail under adversarial input or unusual environments.

Start with the puzzle

A programmer assumes “users will enter normal input.” Why is that assumption dangerous in a security context?

Learning Focus

Identify the software-security weaknesses listed in the lecture and connect them to invalid programming assumptions attackers may deliberately seek.

Where Security Bugs Come From

The lecture identifies invalid programming assumptions as a common reason for security bugs. Attackers do not have to respect the developer's expectations; they actively search for assumptions that can be broken.

Input & memory

Weak input checking; buffer overflow; integer overflow.

Timing & environment

Race condition (Time of Check / Time of Use, TOC/TOU); programs running in new environments.

Configuration & privilege

Log files containing sensitive information; configuration bugs; unnecessary privileges; monoculture; security bypass.

Assumption → Weakness

- “Input is always valid” → weak input checking.
- “Values always fit expected ranges” → integer or buffer overflow.
- “A checked state will not change before it is used” → race condition / TOC-TOU weakness.
- “Logs are harmless” → sensitive information may be exposed in log files.
- “The program will always run in the expected environment” → security assumptions may fail in new environments.

Try it

A search feature places user input directly into a database query without sufficient validation. What is the key Topic 13 lesson?

Self-feedback: External input should not be trusted merely because normal users usually enter normal values. Weak input checking is an exploitable software-security weakness.

TOPIC 13 · LESSON 06

Secure Software Design

Security should shape the design before implementation rather than arrive as a patch after a vulnerability appears.

Start with the puzzle

If a hospital system checks a user's permission only at login and then trusts every later request, what secure-design principle is being violated?

Learning Focus

Recognize the secure software design principles named in the lecture and apply them to access-control and design-review scenarios.

Economy of Mechanism

Design should be small and simple.

Fail-safe Default

The lecture lists fail-safe default as a secure-design principle.

Complete Mediation

Check every access to every object.

Open Design

The lecture lists open design as a secure-design principle.

Separation / Least Privilege

Separate privilege and give users only the privileges necessary for their responsibilities.

Hospital design review

If every employee runs with administrator privileges, Least Privilege is violated. If access is checked only once and later requests are trusted, Complete Mediation points directly at the weakness.

Try it

The system checks access only once, then trusts every later request. Which lecture principle points directly at the weakness?

Self-feedback: Complete Mediation - check every access to every object.

TOPIC 13 · LESSON 07

Malware & Topic Review

Close the topic by defining malware, naming the malware categories in the source, and rebuilding the complete security-and-privacy reasoning chain.

Start with the puzzle

A file looks harmless but is intentionally designed to damage a workstation or gain unauthorized access to patient information. How should it be classified?

Learning Focus

Define malware using the lecture wording, name the malware types listed in the source, and integrate the complete Topic 13 concepts into one security review.

Malware

Malware, or malicious software, refers to software intentionally designed to cause damage to a computer, server, network, or device, or to gain unauthorized access to systems and steal sensitive information. The lecture also describes malicious software as code with intentional, undesirable side effects.

Virus

Named in the supplied lecture slides. The source does not provide a separate behavioral definition for this category, so this study PDF does not invent one.

Worm

Named in the supplied lecture slides. The source does not provide a separate behavioral definition for this category, so this study PDF does not invent one.

Trojan

Named in the supplied lecture slides. The source does not provide a separate behavioral definition for this category, so this study PDF does not invent one.

Spyware

Named in the supplied lecture slides. The source does not provide a separate behavioral definition for this category, so this study PDF does not invent one.

Mission 13 · Protect People, Data & Systems

You are part of the software engineering team supporting Jeddah Smart Hospital. Use the incident board below to apply privacy principles, CIA, threat/vulnerability/attack terminology, user security, password policy, software-security weaknesses, secure-design principles, and malware.

Mission 13

Protect People, Data & Systems

Join the IT team at Jeddah Smart Hospital to investigate security and privacy issues. Make the right decisions to keep patients, data and systems safe.

Protect People

Protect Data

Keep Systems Reliable

مستشفى جدة الذكية
JEDDAH SMART HOSPITAL

Your Role

You are a software engineering team supporting the hospital's information systems. Analyze the situations, identify risks, and choose the best solutions based on security and privacy principles from Topic 13.

Your Goals

- Apply privacy principles (data minimization, anonymization, user consent)
- Understand and apply the CIA triad
- Recognize threats, vulnerabilities and attacks
- Make secure design and user security decisions

1 Patient Registration

A new patient registers through the hospital app. The app asks for personal information to create an account.

Key Question

Which information is necessary, and which should be avoided based on data minimization?

2 Accessing Patient Records

A staff member without a clinical role opens the record of a famous patient just out of curiosity.

Key Question

Which CIA property is violated? What access control principle should prevent this?

3 Suspicious Email

A nurse receives an email with an attachment about "Updated Shift Schedule". The file looks normal.

Key Question

What type of threat is this? What kind of malware could it be? What should the user do?

4 System Outage

Suddenly, the patient appointment system becomes unavailable. Staff cannot access schedules or records.

Key Question

What type of attack is this? Which CIA property is affected? What can be done to reduce the risk?

5 Weak Password

A staff account is found using a weak password and no multi-factor authentication.

Key Question

What makes this password weak? What is a better password policy based on the lecture?

6 Unvalidated Input

A developer is implementing a search feature for patient records. The input is used directly in a database query.

Key Question

What vulnerability is this? How can it be prevented using secure design principles?

7 Mobile App Permissions

The hospital mobile app requests access to the user's location, contacts and photos during installation.

Key Question

Which privacy principle is related to this? What should the app do?

8 Data for Research

Researchers want to use patient data for a study on healthcare trends.

Key Question

What technique should be used to protect patient identity? How can research still be useful?

9 Disaster and Backup

A fire in the data center disrupts some systems. The hospital needs to restore services quickly.

Key Question

Which CIA property is affected? What controls or backup strategies can help maintain it?

10 Secure Design Review

The team reviews a new feature to share patient information between departments.

Key Question

Which secure design principles should be applied? How can the principle of least privilege be enforced?

11 Final Decision

Based on everything you learned, choose the best solutions to protect people, data and systems in the hospital.

Key Question

Bring it all together: What is the best approach for each scenario?

Visual Anchor · Mission 13 scenario board used by the interactive practice.

TOPIC 13 · KEY TAKEAWAYS

Rebuild the Security Story

1

Privacy asks how personal information should be collected, retained, anonymized, and shared with consent.

2

Information security protects information and systems; the CIA triad is Confidentiality, Integrity, and Availability.

3

Threat is a harmful scenario, Vulnerability is the exploitable weakness, and Attack is the attempt to breach security.

4

Identification says who you claim to be; Authentication proves it; Authorization determines what you may access.

5

The lecture password policy combines length, category complexity, and avoidance of meaningful, patterned, or easily guessed passwords.

6

Software-security bugs often arise from invalid programming assumptions, weak input checking, memory/range errors, race conditions, configuration issues, sensitive logs, and unnecessary privileges.

7

Secure design principles in the lecture include Economy of Mechanism, Fail-safe Default, Complete Mediation, Open Design, and Separation/Least Privilege.

8

Malware is intentionally malicious software; the source names Virus, Worm, Trojan, and Spyware.

Whole-Topic Transfer Challenge · Jeddah Smart Hospital

For each incident in Mission 13, answer three questions: (1) What information or system property is at risk? (2) Which Topic 13 concept best describes the problem? (3) What engineering control or design principle from the lecture should guide the response?

Exam Lens

Be able to explain the distinctions, not only recite terms: Privacy vs. Information Security; Confidentiality vs. Integrity vs. Availability; Threat vs. Vulnerability vs. Attack; Identification vs. Authentication vs. Authorization; password length vs. complexity vs. predictability; software-security weakness vs. secure-design principle.

Remember

The strongest answer connects a concrete scenario to the correct concept and explains why that concept fits.

Source boundary

This study edition is grounded in the supplied Security and Privacy lecture and the live Topic 13 course pages. Where the source only names a concept (for example individual malware categories or some secure-design principles), the PDF preserves that boundary instead of adding unsupported definitions.